TEST PLAN · VWO-49

# Add Passkey and SSO Login Options to VWO Login Page

DRAFT: PENDING HUMAN REVIEW

| PRODUCT | DOMAIN | ORGANISATION SIZE | PLAN DATE |
|---|---|---|---|
| VWO (vwo.com) | A/B testing for websites | ~5,000 employees | 25 Oct 2026 |

Status: **DRAFT, pending human review.** Not approved until a QA owner signs off. Every scenario traces to an acceptance criterion (AC) or a gap (G). Nothing here adds requirements that are not in the ticket; missing information is listed as a question.

## 0 Ticket snapshot

| Field | Value |
|---|---|
| **Key** | VWO-49 |
| **Summary** | [VWO] Add Passkey and SSO Login Options to VWO Login Page |
| **Issue type** | Story |
| **Priority (Jira field)** | Medium |
| **Priority (in description)** | High (conflicts with the Jira field, see G-01) |
| **Epic (text only, not linked)** | Authentication Enhancements |
| **Components / Labels** | None |
| **Fix version / Sprint** | None |
| **Linked issues** | None |
| **Attachments / designs** | None |
| **Fetched** | 2026-10-25 via scripts/fetch-jira.sh (Jira REST API v3) |

### User story

As a user, I want to log in using either Passkey or Single Sign-On (SSO), so that I can access my account more securely and conveniently without relying solely on email/password authentication.

### Acceptance criteria (as written, condensed)

| # | Area | Criterion |
|---|---|---|
| **AC1** | UI Visibility | On the login page, the buttons “Sign in using SSO” and “Sign in with Passkey” are visible and displayed below the “Sign in with Google” option. |
| **AC2** | SSO Login Flow | Clicking “Sign in using SSO” with valid SSO credentials authenticates the user and redirects to the dashboard. Appropriate error messages are shown for invalid credentials. |
| **AC3** | Passkey Login Flow | Clicking “Sign in with Passkey” with a registered, verified passkey logs the user in and redirects to the dashboard. If no passkey is available, a fallback or guidance message is displayed. |
| **AC4** | Error Handling | Proper error messages for: failed SSO authentication, passkey authentication failure, unsupported browser/device for passkeys. |
| **AC5** | Compatibility | Passkey login works on supported browsers/devices only. SSO works across all configured identity providers. |
| **AC6** | Security | All authentication flows follow secure protocols (OAuth/SAML/WebAuthn). No sensitive data is exposed in UI or network logs. |

### Out of scope (from ticket)

- Passkey registration flow (covered in a separate story)
- SSO provider configuration

### Definition of Done (from ticket)

- Feature implemented and deployed to staging
- All acceptance criteria met
- QA sign-off completed
- No critical or high defects open
- Documentation updated

## 1 Scope & Objectives

**In scope**

- Login page UI: the two new buttons, their labels and placement below “Sign in with Google” (AC1).
- SSO login for every configured identity provider, success and failure paths (AC2, AC4, AC5).
- Passkey login with a registered passkey, the no-passkey path and unsupported browsers/devices (AC3, AC4, AC5).
- Security of both flows: protocol checks and no sensitive data in UI or network logs (AC6).
- Responsiveness and accessibility of the new buttons (ticket scenario 7).
- Regression of existing login methods on the same page (email/password, Google).

**Out of scope**

- Passkey registration flow (separate story, per ticket).
- SSO provider configuration (per ticket); it is still a precondition for testing, see R2.
- Load / performance testing, until a target is given (G-15).
- Detailed test cases and automation, until this plan is approved.

**Objective:** show, with evidence on staging, that users can sign in with SSO and with a passkey and reach the dashboard; that every failure shows the agreed message and creates no session; that no sensitive data leaks; and that existing login methods still work. “Tested” means all six ACs verified and the exit criteria in section 6 met.

## 2 Gaps & Questions for the author

### 2.1 Requirement checklist result (references/requirement-checklist.md)

| 1 | 13 | 8 |
|---|---|---|
| Present of 22 items | Ambiguous of 22 items | Missing of 22 items |

| Area | Checklist item | Result | Evidence from the ticket | See |
|---|---|---|---|---|
| Functional | Clear user story / goal | Present | Standard “As a user… so that…” story is present. | |
| Functional | Acceptance criteria are testable | Ambiguous | AC2 to AC4 rely on “appropriate / proper” messages; AC5 “supported” is undefined. | G-07, G-10 |
| Functional | Happy path fully described | Ambiguous | End state (dashboard) is defined; the steps between the click and the IdP / passkey prompt are not. | G-04, G-08 |
| Functional | Negative / error paths described | Ambiguous | Three error categories listed; cancel, timeout, IdP down and unprovisioned users are not. | G-06, G-07 |
| Functional | Boundary & empty states | Missing | Multiple passkeys or accounts on one device, no SSO configured, multi-workspace users. | G-08, G-11 |
| Functional | State transitions / workflow steps | Ambiguous | Redirect target, session lifetime and logout are not defined. | G-11, G-13 |
| Data & environment | Required test data specified | Missing | No test users, IdP tenants or registered passkeys named. | G-05, G-17 |

| Area | Checklist item | Result | Evidence from the ticket | See |
|---|---|---|---|---|
| Data & environment | Environment / config / feature flags | Ambiguous | Staging is implied by the DoD; no feature flag mentioned. | G-16 |
| Data & environment | External dependencies listed | Ambiguous | IdPs and WebAuthn are mentioned generically, none named. | G-05 |
| Data & environment | Preconditions / setup stated | Ambiguous | Registered passkey and IdP config are needed but are out of scope. | G-17 |
| Non-functional | Performance / load expectations | Missing | No login time or load target. | G-15 |
| Non-functional | Security / authorization (roles) | Ambiguous | Protocols listed; roles, plans and enforcement rules are not. | G-05, G-12, G-14, G-16 |
| Non-functional | Accessibility expectations | Ambiguous | Mentioned in ticket scenario 7; no standard (e.g. WCAG level) given. | G-15 |
| Non-functional | Internationalization / localization | Missing | No requirement for translated labels or error messages. | G-15 |
| Non-functional | Audit / logging / observability | Missing | Only “no sensitive data in logs”; no audit trail requirement. | G-14, G-15 |
| Cross-cutting | Impact on existing features | Ambiguous | New options sit “alongside existing methods”; regression not called out. | TS-03 |
| Cross-cutting | Backward compatibility / migration | Missing | Account linking, 2FA users and SSO-enforced accounts not covered. | G-12 |
| Cross-cutting | Mobile / responsive / browser matrix | Ambiguous | “Supported browsers/devices” and responsiveness not defined. | G-10 |
| Cross-cutting | Rollback / feature-flag behavior | Missing | No rollout or rollback plan. | G-16 |
| Clarity | No ambiguous wording | Ambiguous | “Seamlessly”, “smooth”, “appropriate”, “proper”, “fallback or guidance”. | G-07 |
| Clarity | Terms defined consistently | Ambiguous | Priority Medium vs High; “have been added” vs “should”. | G-01, G-18 |
| Clarity | Mockups / designs linked | Missing | No attachments or design links on the ticket. | G-03 |

### 2.2 Questions for the author

Questions marked **Blocking** must be answered before execution starts (entry criteria). 5 of 19 are blocking.

| # | Area | Finding | Question to author | Blocks |
|---|---|---|---|---|
| **G-01** | Ticket hygiene | Ambiguous Jira priority field is Medium; the description says High. | Which priority is correct? It decides test depth and scheduling. | |
| **G-02** | Traceability | Missing Epic appears only as text. No issue links, components, fix version or sprint. | Can you link the epic and the passkey registration story, and set the fix version / sprint? | |
| **G-03** | Designs | Missing No mockups or attachments. | Where are the designs (order, styling, icons, mobile layout)? Are the labels “Sign in using SSO” and “Sign in with Passkey” final, given the different wording? | |

| # | Area | Finding | Question to author | Blocks |
|---|---|---|---|---|
| **G-04** | SSO flow | **Ambiguous** The step after clicking “Sign in using SSO” is not described. | How is the user's IdP found: work email / domain, org ID, or a single IdP? Is IdP-initiated login (from the IdP portal) also in scope? | **Blocking** |
| **G-05** | SSO protocols & IdPs | **Ambiguous** AC6 lists OAuth/SAML/WebAuthn; “configured identity providers” are not named. | Which protocols does SSO use (SAML 2.0, OIDC, both)? Which IdPs are configured on staging for testing? | **Blocking** |
| **G-06** | Provisioning | **Missing** No behavior for users the IdP accepts but VWO does not know, or has disabled. | Is there just-in-time provisioning, or an error? What message is shown? | |
| **G-07** | Error copy | **Ambiguous** “Appropriate / proper error messages” and “fallback or guidance message” are undefined. | Please share the exact text for: invalid SSO credentials, SSO cancelled, IdP unavailable, passkey failure, no passkey, unsupported browser/device. | **Blocking** |
| **G-08** | Passkey flow | **Ambiguous** The passkey interaction model is not described. | Usernameless (account picker) or email first? Is browser autofill (conditional UI) in scope? Is cross-device sign-in (QR code from a phone) in scope? | |
| **G-09** | Unsupported devices | **Ambiguous** AC4 needs a message, but the button state is undefined. | On unsupported browsers/devices, is the passkey button hidden, disabled, or shown with a message on click? | |
| **G-10** | Compatibility matrix | **Missing** “Supported browsers/devices” is not defined. | Which browsers, OS versions and devices are supported for passkeys and SSO? Is mobile web in scope? | **Blocking** |
| **G-11** | Post-login redirect | **Ambiguous** AC2 / AC3 say “redirected to the dashboard”. | Always the dashboard, or back to the page the user originally requested? For users in several VWO accounts, which account? | |
| **G-12** | Existing auth rules | **Missing** No interplay with 2FA, SSO-enforced accounts or account linking. | Is 2FA asked after SSO / passkey? Can SSO-enforced users still use password or Google? How are password and SSO identities linked? | |
| **G-13** | Session & logout | **Missing** Session lifetime and logout are not defined. | What is the session lifetime for these logins? Does VWO logout also end the IdP session (single logout)? | |
| **G-14** | Security detail | **Ambiguous** “No sensitive data in UI or network logs” is not itemised. | Which data counts as sensitive (tokens, SAML assertions, emails, user IDs)? Is a security review planned? Any rate-limit expectation? | |
| **G-15** | Non-functional | **Missing** No performance, accessibility standard, i18n or audit requirements. | Is there a login time target, a WCAG level, translated copy, or an audit-log entry for these logins? | |
| **G-16** | Rollout | **Missing** No feature flag, rollout or rollback plan; no plan / role limits. | Is this behind a feature flag? Is it for all plans and roles, or only some (e.g. Enterprise)? | |
| **G-17** | Test dependency | **Ambiguous** Passkey registration is out of scope, but passkey login needs a registered passkey. | How will QA get registered passkeys on staging: is the registration story already deployed, or can credentials be seeded? | **Blocking** |
| **G-18** | Wording | **Ambiguous** Description says the options “have been added”; the ACs say “should”. | Is the feature already built and on staging, or still in development? | |

| # | Area | Finding | Question to author | Blocks |
|---|---|---|---|---|
| G-19 | Ticket hygiene | Ambiguous The description ends with leftover AI-assistant text ("If you want, I can also generate test cases…"). | Please remove it so the ticket reads only as the requirement. | |

## 3 Test Scenarios (P0 / P1 / P2)

| 34 | 10 | 15 | 9 |
|---|---|---|---|
| scenarios in total | P0 must pass to ship | P1 pass or agreed deferral | P2 if time allows |

P0: login blocked, security exposure or core AC. P1: important AC path or a likely real-world failure. P2: polish, or depends on an open question.

### A. Login page UI

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-01 | P1 | Positive | Open the login page: "Sign in using SSO" and "Sign in with Passkey" are visible with the exact labels. | AC1 |
| TS-02 | P1 | Positive | Both new buttons appear below "Sign in with Google", in the order shown in the design. | AC1, G-03 |
| TS-03 | P0 | Regression | Email/password and "Sign in with Google" still render and log in successfully after the layout change. | AC1 |
| TS-04 | P2 | Positive | Login page at mobile, tablet and desktop widths: buttons are not clipped, overlapping or reordered. | AC1, G-03 |
| TS-05 | P2 | Positive | Keyboard and screen reader: buttons reachable by Tab in logical order, activate with Enter/Space, visible focus, accessible names match labels; automated a11y scan clean. | AC1, G-15 |

### B. SSO login

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-06 | P0 | Positive | Valid SSO user clicks "Sign in using SSO", signs in at the IdP and lands on the VWO dashboard with a valid session. | AC2 |
| TS-07 | P0 | Positive | Repeat TS-06 for each configured IdP and protocol (SAML / OIDC as applicable). | AC5, G-05 |
| TS-08 | P0 | Negative | Wrong credentials at the IdP: the defined SSO failure message is shown and no VWO session is created. | AC2, AC4 |
| TS-09 | P1 | Negative | User cancels or closes the IdP login and comes back: returned to the VWO login page with a message, can pick another method. | AC4, G-07 |
| TS-10 | P1 | Negative | IdP accepts the user but VWO has no account for them, or the VWO user is disabled: access denied with the defined message (or provisioned, per G-06). | G-06 |
| TS-11 | P1 | Negative | User whose email / org has no SSO configured tries SSO: guidance message, no redirect loop. | G-04 |
| TS-12 | P1 | Negative | IdP unreachable or timing out: error shown, other login methods still usable. | AC4, G-07 |
| TS-13 | P0 | Security | Tampered, expired or replayed SAML response, or an OIDC callback with a wrong state / nonce: rejected, no session. | AC6 |

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-14 | P2 | Positive | Open a protected VWO URL while logged out, sign in via SSO: lands on the target page or the dashboard, per G-11. | G-11 |

### C. Passkey login

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-15 | P0 | Positive | User with a registered passkey clicks “Sign in with Passkey”, verifies (biometric / PIN) and lands on the dashboard with a valid session. | AC3 |
| TS-16 | P0 | Negative | No passkey for VWO on this device or account: the fallback / guidance message is displayed. | AC3, G-07 |
| TS-17 | P0 | Negative | User cancels the browser / OS passkey prompt: passkey failure message, can retry or use another method. | AC4 |
| TS-18 | P1 | Negative | Verification fails or the prompt times out: passkey failure message, no session. | AC4 |
| TS-19 | P1 | Negative | Unsupported browser / device (no WebAuthn): unsupported message shown; button state per G-09. | AC4, AC5, G-09 |
| TS-20 | P1 | Boundary | Device holds passkeys for several VWO users: account chooser shown; only the selected account is logged in. | G-08 |
| TS-21 | P1 | Negative | Passkey belongs to a disabled or deleted VWO user: login rejected with the defined message. | G-06 |
| TS-22 | P2 | Positive | Cross-device passkey (QR code from a phone), only if G-08 confirms it is in scope. | G-08 |
| TS-23 | P0 | Security | Passkey assertion from a different origin / RP ID, or a replayed assertion, is rejected by the server. | AC6 |

### D. Compatibility

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-24 | P1 | Positive | Passkey login across the agreed matrix (browsers x OS x platform authenticators). | AC5, G-10 |
| TS-25 | P2 | Positive | SSO login across the supported browsers, including browsers with strict third-party cookie rules. | AC5, G-10 |

### E. Security

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-26 | P0 | Security | Inspect UI, URLs, browser console and network HAR for both flows: no passwords, tokens, SAML assertions or secrets exposed. | AC6, G-14 |
| TS-27 | P1 | Security | After login: session cookie is Secure / HttpOnly / SameSite, session ID changes on login, logout invalidates the session. | AC6, G-13 |
| TS-28 | P2 | Security | Repeated failed SSO / passkey attempts: rate-limit or lockout behavior per G-14. | G-14 |

### F. Cross-cutting

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| TS-29 | P1 | Positive | 2FA-enabled user signs in via SSO and via passkey: 2FA behavior matches the answer to G-12. | G-12 |

| ID | Priority | Type | Scenario and expected result | Maps to |
|---|---|---|---|---|
| **TS-30** | P1 | Positive | SSO-enforced account: password / Google login blocked or allowed, per G-12. | G-12 |
| **TS-31** | P1 | Positive | Logout after an SSO / passkey login ends the VWO session; IdP session behavior per G-13. | G-13 |
| **TS-32** | P2 | Positive | New labels and error messages in each supported UI language (if the login page is localized). | G-15 |
| **TS-33** | P2 | Positive | SSO and passkey logins (success and failure) appear in the audit / activity log, if required. | G-15 |
| **TS-34** | P2 | Positive | Feature flag off (if one exists): new buttons hidden, existing login unaffected. | G-16 |

### 3.1 Traceability: acceptance criteria to scenarios

| Acceptance criterion | Covered by |
|---|---|
| **AC1 UI Visibility** | TS-01, TS-02, TS-03, TS-04, TS-05 |
| **AC2 SSO Login Flow** | TS-06, TS-08 |
| **AC3 Passkey Login Flow** | TS-15, TS-16 |
| **AC4 Error Handling** | TS-08, TS-09, TS-12, TS-17, TS-18, TS-19 |
| **AC5 Compatibility** | TS-07, TS-19, TS-24, TS-25 |
| **AC6 Security** | TS-13, TS-23, TS-26, TS-27 |

### 3.2 Ticket's own test scenarios to plan scenarios

| Scenario listed in VWO-49 | Covered by |
|---|---|
| **Verify both new buttons are visible and correctly positioned** | TS-01, TS-02 |
| **Validate successful login via SSO** | TS-06, TS-07 |
| **Validate failed SSO login with incorrect credentials** | TS-08 |
| **Validate successful login via Passkey** | TS-15 |
| **Validate behavior when no passkey is registered** | TS-16 |
| **Validate behavior on unsupported browsers/devices** | TS-19 |
| **Verify UI responsiveness and accessibility** | TS-04, TS-05 |

## 4 Test Data & Environment

**Data**

- VWO user with a registered passkey on each test device (depends on G-17).
- VWO user with no passkey.
- SSO-enabled VWO account with IdP test users: valid; wrong password; known to the IdP but not to VWO; disabled in VWO.
- VWO account with no SSO configured.
- 2FA-enabled user and an SSO-enforced account, if those apply (G-12).

- User who belongs to more than one VWO account (G-11).

**Environment / flags**

- Staging (Definition of Done).
- Test IdP tenant(s) configured on staging. Configuration is out of scope for this story, so an owner is needed (R2).
- Real devices with platform authenticators for manual passkey runs; Chrome's virtual authenticator for repeatable runs and later automation.
- Browser / device matrix: to be agreed (G-10).
- Feature flag: unknown (G-16).
- Tools: browser DevTools and HAR capture, a SAML tracer for SAML inspection, axe or Lighthouse and a screen reader for accessibility.

**Roles / permissions:** the ticket only says “a user”. Roles, plans and SSO enforcement are not specified (G-12, G-16).

## 5 Risks & Assumptions

### Assumptions made

| # | Assumption |
|---|---|
| **A1** | “Dashboard” means the default VWO page a user lands on after login. |
| **A2** | Testing runs on staging, as stated in the Definition of Done. |
| **A3** | SSO starts from the VWO login page (SP-initiated). IdP-initiated login is not covered until G-04 is answered. |
| **A4** | Passkeys are implemented with WebAuthn, as AC6 states. |
| **A5** | Test depth is sized for High priority (login is the entry point for every customer) until G-01 is resolved. |
| **A6** | Existing login methods (email/password, Google) are in regression scope because they share the page. |

### Risks

| # | Level | Risk | Mitigation |
|---|---|---|---|
| **R1** | High | Passkey login cannot be tested end to end if the registration story is not on staging. | Answer G-17; seed credentials or use a virtual authenticator. |
| **R2** | High | No test IdP configured on staging (configuration is out of scope) blocks every SSO scenario. | Name an owner for IdP setup before entry. |
| **R3** | High | Login is the entry point for every customer; a regression locks users out. | TS-03 as P0, plus a full login regression run. |
| **R4** | High | Flaws in assertion or origin validation could allow account takeover. | TS-13, TS-23, TS-26; request a security review (G-14). |
| **R5** | Medium | Undefined error copy leads to pass / fail disputes. | Agree exact messages via G-07 before execution. |
| **R6** | Medium | WebAuthn prompts differ by browser and OS; an undefined matrix causes scope creep. | Fix the support matrix via G-10. |
| **R7** | Low | Priority mismatch may push the story out of the planned sprint. | Resolve G-01. |

## 6 Entry / Exit criteria

### Entry

- Build with both login options deployed to staging.
- At least one test IdP configured on staging, with test users (R2).
- Registered passkeys available for test users (G-17).
- Blocking questions answered: G-04, G-05, G-07, G-10, G-17.
- Test data from section 4 created; browser / device matrix agreed.
- This plan approved by the QA owner.

### Exit

- All P0 scenarios passed.
- All P1 scenarios passed, or failures logged with an agreed deferral.
- No open Critical or High defects (Definition of Done).
- Regression of email/password and Google sign-in passed.
- AC6 security checks (TS-13, TS-23, TS-26, TS-27) passed with evidence.
- QA sign-off recorded and documentation updated (Definition of Done).

## 7 Resource Allocation

*Not specified in the ticket. Names and effort to be filled in by the QA lead.*

| Role needed | Why | Owner |
|---|---|---|
| QA engineer(s) | Functional, negative and compatibility runs (sections A to D, F) | *TBD* |
| IdP admin (staging) | Create test IdP tenant and users (R2) | *TBD* |
| Security reviewer | AC6 checks and protocol review (R4, G-14) | *TBD* |
| Device pool owner | Real devices for the passkey matrix (G-10) | *TBD* |

## 8 Timelines, Sprint Details

*The ticket has no sprint, fix version or due date (G-02). Epic named in text: Authentication Enhancements. Dates to be set once G-01 and G-02 are resolved.*

### HUMAN REVIEW GATE

**I assumed:** A1 to A6 in section 5 (dashboard landing page, staging, SP-initiated SSO, WebAuthn passkeys, High-priority depth, existing login in regression scope).

**I could not confirm:** designs and final labels; which IdPs and protocols are configured; the supported browser / device matrix; the exact error and guidance text; whether passkey registration is on staging; sprint, fix version and owners.

**Open questions blocking sign-off:** G-04, G-05, G-07, G-10, G-17 (section 2.2). G-01 (priority) also affects scheduling.

**Approve, or edit, before I write test cases or automation.**

Reviewed by (QA owner) _____ Date _____ Decision: Approve / Approve with changes / Reject _____